

Report Esercizio Bonus: Deep Dive Nmap

Cos'è nmap? Per cosa viene usato?

Nmap ("Network Mapper") è uno strumento open source per l'esplorazione della rete e l'auditing di sicurezza. È stato progettato per scansionare rapidamente reti di grandi dimensioni, sebbene funzioni benissimo anche su singoli host. Nmap utilizza pacchetti IP grezzi (raw) in modi innovativi per determinare quali host sono disponibili sulla rete, quali servizi (nome e versione dell'applicazione) offrono questi host, quali sistemi operativi (e relative versioni) eseguono, quale tipo di filtri di pacchetti/firewall sono in uso e decine di altre caratteristiche. Sebbene Nmap sia comunemente utilizzato per gli audit di sicurezza, molti amministratori di sistemi e di rete lo trovano utile per attività di routine come l'inventario di rete, la gestione delle pianificazioni di aggiornamento dei servizi e il monitoraggio del tempo di attività (uptime) di host o servizi.

L'output di Nmap è un elenco di target scansionati, con informazioni supplementari su ciascuno a seconda delle opzioni utilizzate. Tra queste informazioni, di fondamentale importanza è la "tabella delle porte interessanti" (*interesting ports table*). Questa tabella elenca il numero e il protocollo della porta, il nome del servizio e lo stato. Lo stato può essere aperto (*open*), filtrato (*filtered*), chiuso (*closed*) o non filtrato (*unfiltered*).

Nmap riporta le combinazioni di stato *open|filtered* (aperta|filtrata) e *closed|filtered* (chiusa|filtrata) quando non è in grado di determinare quale dei due stati descriva una porta. La tabella delle porte può anche includere i dettagli sulla versione del software quando è stato richiesto il rilevamento della versione (*version detection*). Quando viene richiesta una scansione del protocollo IP (*-s0*), Nmap fornisce informazioni sui protocolli IP supportati piuttosto che sulle porte in ascolto.

Qual è il comando nmap usato?

A typical Nmap scan is shown in **Example 1**. The only Nmap arguments used in this **example** are **-A**, to enable OS and version detection, script scanning, and traceroute; **-T4** for faster execution; and then the hostname.

Example 1. A representative Nmap scan

```
# nmap -A -T4 scanme.nmap.org
```

Lo scan utilizzato nell'esempio è `nmap -A -T4 scanme.nmap.org`

L'opzione **-A (Aggressive Scan):** Questa è una delle opzioni più complete di Nmap. Abilitandola, indichi a Nmap di eseguire una scansione "aggressiva" che combina diverse funzionalità avanzate in un colpo solo. Nello specifico, attiva contemporaneamente:

- Il rilevamento del sistema operativo (**-O**).
- Il rilevamento della versione dei servizi in esecuzione sulle porte (**-sV**).
- La scansione tramite gli script di default dell'Nmap Scripting Engine (**-sC**).
- Il tracciamento del percorso di rete verso il target (**--traceroute**). È estremamente utile per ottenere una panoramica dettagliata del bersaglio, ma è anche molto "rumorosa" e facilmente rilevabile dai firewall o dai sistemi di intrusione (IDS/IPS).

L'opzione **-T4 (Timing Template - Aggressive):** Nmap utilizza dei "template di temporizzazione" (da **-T0** a **-T5**) per stabilire quanto velocemente deve inviare i pacchetti e quanto tempo deve attendere le risposte.

- **-T4** è il template "Aggressive" (Aggressivo).
- Viene utilizzato per velocizzare notevolmente la scansione rispetto al valore di default (**-T3**), riducendo i tempi di timeout e inviando pacchetti più rapidamente.
- È ideale quando si scansionano reti moderne, veloci e affidabili (es. una rete locale aziendale o una connessione a banda larga stabile), ma può causare la perdita di qualche pacchetto (e quindi di qualche informazione) su reti congestionate o instabili.

Ricapitolando, questo comando chiede ad nmap di lanciare una scansione per raccogliere il maggior numero di informazioni (sistema operativo, versioni, script) e di farlo in modo molto veloce.

Passo 1: Scansiona il tuo localhost

```
[analyst@secOps ~]$ man nmap
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-21 04:27 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000086s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 127.0.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
```

In questo scan, possiamo notare la porta 21 (TCP) aperta, che gestisce il servizio FTP alla versione vsftpd 3-0-5, e la porta 22 (TCP) con servizio ssh attivo alla versione OpenSSH 10.0 (protocollo 2.0)

Passo 2: Scansiona la tua rete

Per fini di laboratorio e per vedere effettivamente quanti indirizzi IP fossero connessi alla mia rete, sono passato ad una scheda di rete in Bridge, e ho lanciato il comando `nmap -A -T4 [mio_ip/cidr]`

A quale rete appartiene la tua VM?

```
[analyst@secOps ~]$ ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.109 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::a00:27ff:fe2f:87a7 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:2f:87:a7 txqueuelen 1000 (Ethernet)
    RX packets 11614 bytes 895500 (874.5 KiB)
    RX errors 0 dropped 2 overruns 0 frame 0
    TX packets 16236 bytes 1393538 (1.3 MiB)
    TX errors 0 dropped 1 overruns 0 carrier 0 collisions 0

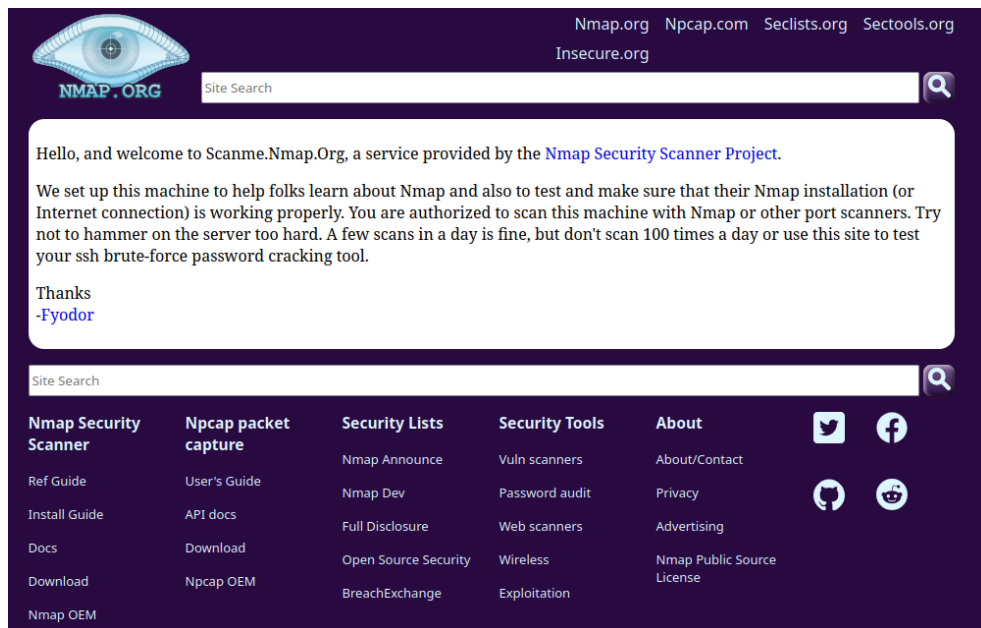
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8534 bytes 533294 (520.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8534 bytes 533294 (520.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Quanti host sono attivi?

La scansione con nmap ha trovato 9 hosts attivi sulla mia rete, allego uno screen di un ping sweep per una più facile lettura.

```
[analyst@secOps ~]$ nmap -sn 192.168.1.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-21 04:56 -0500
Nmap scan report for 192.168.1.1
Host is up (0.0032s latency).
Nmap scan report for 192.168.1.100
Host is up (0.0062s latency).
Nmap scan report for 192.168.1.109
Host is up (0.00019s latency).
Nmap scan report for 192.168.1.116
Host is up (0.040s latency).
Nmap scan report for 192.168.1.117
Host is up (0.00061s latency).
Nmap scan report for 192.168.1.133
Host is up (0.061s latency).
Nmap scan report for 192.168.1.141
Host is up (0.026s latency).
Nmap scan report for 192.168.1.145
Host is up (0.018s latency).
Nmap scan report for 192.168.1.149
Host is up (0.0034s latency).
Nmap done: 256 IP addresses (9 hosts up) scanned in 44.93 seconds
```

Passo 3: Scansiona un server remoto



Utilizzando scanme.nmap.org possiamo testare la connessione ad un server remoto tramite il comando `nmap -A -T4 scanme.nmap.org`

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-21 05:02 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (conn-refused)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http           Apache httpd 2.4.7 ((Ubuntu))
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
|_ http-title: Go ahead and ScanMe!
1719/tcp  filtered h323gatestat
9929/tcp  open  nping-echo     Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.15 seconds
```

Domanda di riflessione

1. Introduzione

Nmap (Network Mapper) rappresenta uno standard de facto per l'esplorazione e l'auditing delle infrastrutture di rete. In ambito di cybersecurity, si configura come uno strumento "dual-use": le medesime capacità tecniche che consentono a un amministratore di proteggere un perimetro aziendale possono essere sfruttate da un attore ostile per pianificare e condurre un attacco. La discriminante tra le due modalità operative risiede unicamente nell'autorizzazione e nell'intento.

2. Applicazioni Difensive e Mitigazione del Rischio (Blue Team)

Nell'ambito della gestione proattiva della sicurezza, Nmap è un componente essenziale per la visibilità e il controllo dell'infrastruttura. Le sue principali applicazioni difensive includono:

- **Inventario e Visibilità dell'Infrastruttura:** Permette la mappatura esatta dei dispositivi connessi, facilitando l'individuazione di hardware non autorizzato (fenomeno dello Shadow IT) o di segmenti di rete non documentati.
- **Auditing della Superficie di Attacco:** Attraverso la scansione periodica dei server esposti, gli amministratori possono verificare la coerenza tra i servizi effettivamente in ascolto e le policy aziendali, chiudendo tempestivamente porte esposte per errore (es. servizi RDP o database non protetti).
- **Validazione delle Regole di Rete:** L'analisi degli stati delle porte (es. "open", "filtered", "closed") consente di certificare il corretto funzionamento e l'efficacia dei firewall e dei sistemi di Intrusion Detection/Prevention (IDS/IPS).
- **Vulnerability Assessment:** Grazie all'integrazione del Nmap Scripting Engine (NSE), i team di sicurezza possono condurre scansioni mirate per individuare software obsoleti o vulnerabilità note (CVE) prima che vengano sfruttate da terzi.

3. Sfruttamento Offensivo e Vettori di Minaccia (Attori Malevoli)

Dal punto di vista di un attaccante, Nmap costituisce lo strumento primario per la fase di ricognizione (Reconnaissance) e per l'identificazione dei vettori di compromissione iniziale:

- **Mappatura del Bersaglio (Footprinting):** L'attore ostile utilizza lo strumento per ricostruire la topologia della rete bersaglio, individuare i server critici e operare l'OS Fingerprinting per determinare i sistemi operativi in uso.

- **Identificazione delle Vulnerabilità:** Eseguendo scansioni mirate all'individuazione delle versioni dei servizi (-sV), l'attaccante cerca specificamente software non aggiornati o configurazioni predefinite deboli, che rappresentano il punto di ingresso per l'iniezione di payload o RAT.
- **Pianificazione del Movimento Laterale:** A seguito della compromissione di un singolo host, Nmap viene spesso impiegato dall'interno della rete per mappare le subnet locali e identificare ulteriori target vulnerabili, espandendo il perimetro dell'infezione.
- **Tecniche di Evasione:** Per non allertare i sistemi di difesa (SOC/SIEM), gli attaccanti adottano tecniche di scansione avanzate e a basso rumore. Queste includono la frammentazione dei pacchetti, l'impiego di indirizzi IP esca (Decoy) e l'utilizzo di template di temporizzazione estremamente lenti, rendendo il traffico difficilmente distinguibile dalle normali fluttuazioni di rete.

4. Conclusioni

L'efficacia di Nmap impone l'adozione di un approccio di "difesa in profondità" (Defense-in-Depth). La consapevolezza delle metodologie di scansione offensive è un prerequisito fondamentale per la corretta configurazione dei sistemi di monitoraggio e per la stesura di regole di rilevamento in grado di identificare e bloccare le attività di ricognizione non autorizzate.